FINTECHATHON 2026 · INTERNATIONAL TRACK · TOPIC C

Kassa

An AI agent that pays your bills across borders, inside the limits you signed.

AI as a financial participant: it prepares every payment; only your passkey, now or in a mandate signed earlier, moves money.

Sandbox and simulated rails only · no real money moves

THE PROBLEM

Dana’s money arrives in KZT and USD. Her bills are in HUF and EUR.

Hidden FX costs

Card markups over the mid rate and dynamic currency conversion eat a student budget quietly.

Irregular money from home

A big transfer one month is not a salary. Planning with the best month leads to rent shortfalls.

Scams that look like bills

“Your landlord’s IBAN changed” emails and fake “safe account” calls target newcomers abroad.

Hero user: Dana, a Kazakh master’s student in Budapest (fictitious persona)

AI AS A FINANCIAL PARTICIPANT

Not a wallet with a chatbot. An agent with a signed job description.

1

The agent proposes

Reads balances, bills, history and documents. Drafts an exact order. It has no payment tool.

2

Code decides

Plain rules, not the model: caps, verified payees, 24 h cooling, sanctions screening.

3

Your passkey signs

Now, for this exact order, or earlier, in a mandate (rent, insurance, small purchases).

WHAT THE AGENT DOES

Real financial work, every day

Plans bills against a 45-day forecast

Rent, tuition and insurance per currency; flags the day a balance would fall below your reserve.

Fee x-ray and cheapest route

Shows each card’s markup over the mid rate and picks the cheapest way to fund each bill.

Logs spending in every currency

Card taps, wallet notifications and an iOS Shortcut, categorised, with budgets and pace.

Builds a credit record

A signed, verifiable summary of bills paid on time, for a landlord or bank abroad.

IT KNOWS YOUR PAST, THEN PLANS

Upload your bank statements. Kassa learns how your money really behaves.

1,501
rows read from 3 real statements (Kazakh, Russian, English) by plain code, no AI call (one local run; statements kept private)

0
account numbers, IBANs or ID numbers kept or sent to a model

38%
left uncategorised without AI, down from 60% with local chain names

It finds each statement’s period, how regular money from home is (in how many months it came, its range, whether it stopped), one-off payments and transfers between your own accounts. The forecast and the agent plan with the average, not the best month.

CREDIT BUILDING

A new country means no credit history. Kassa turns paid bills into one a landlord can check.

Pick

A period and what to share: bills paid on time, income, budgets. Nothing else leaves.

Sign

Ed25519-signed summary and PDF, written to the tamper-evident ledger.

Verify

A public link checks the signature and the ledger entry. No account needed.

apps/api/src/modules/credit-record/ · app: Credit record screen · demo beat 5

THE DEMO

Five minutes with Dana

1. The agent meets Dana (live AI): reads her bank statements, drafts caps and budgets, she signs with a passkey
2. Money from home pays tuition: KZT arrives, cheapest route, EUR 2,400 approved on the exact order
3. Rent day: the agent pays on its own inside the signed mandate
4. Attacks fail: the lookalike landlord IBAN is held, hidden invoice text is treated as data
5. Credit record: a signed six-month record and the landlord's verify link

Live: kassa-sand.vercel.app · without a passkey device: kassa-judge.vercel.app · script: docs/submission/demo-script.md

SYSTEM ARCHITECTURE

Two AI calls, both fenced in. Everything that moves money is plain code.

Planner (AI)

Reads tools, drafts orders. Only money tool: propose_order. Sees redacted placeholders, never IBANs.

Reader (AI)

Untrusted documents in, typed fields out. No tools, no memory. Every field must be found in the source.

Rules

Pure decide(): AUTO, ASK, HANDOFF or REFUSE. Builds the canonical order and signs approvals (Ed25519).

Payments

Re-checks signature, payee, caps, screening and identity on its own. Single-use nonces.

Ledger

Append-only hash chain, signed checkpoints every 20 entries and a signed head.

Lint rules forbid the agent module from importing payments, rails or the ledger internals. The app (web, iOS, KassaLite) talks to one Fastify API; banks, shops and schools are a simulated world over HMAC-signed webhooks.

docs/architecture/overview.md §1–3 · TypeScript, Bun, Fastify, Drizzle, Expo, Vercel AI SDK (any model provider)

CORE ALGORITHMS

Three formulas the model never overrides

Cheapest route

$$cost = fee + A \cdot rate \cdot \frac{markupBps}{10{,}000}$$

Every funding currency × rail. Dropped if it arrives after the due date, overdraws the balance or breaks the rail cap. Top 3 with savings vs the worst.

45-day coverage

$$B(t) = B(0) + incomes - bills - burn \cdot t$$

Per currency, day by day. Burn is the median daily spend of the last 30 days, or the statement history when that is thin. Flags the first day under the reserve.

Risk score

$$R = \Sigma\, w_i \cdot f_i, \text{ ask at } R \geq 0.5$$

New payee 0.30, budget share 0.20, price above median 0.15, quantity 0.10, trigger origin 0.10, unverified field 0.10, night 0.05.

Then a fixed decision order, first match wins: frozen, unverified or cooling payee, reader mismatch, sanctions, caps, China handoff, identity (KYC), mandate, risk, small auto.

docs/architecture/overview.md §4.1–4.5 · code: fx/routes.ts, fx/forecast.ts, rules/risk.ts, rules/decide.ts

PERMISSION TIERS

What the agent may do, decided in code

Tier	What happens	Who decides
T0 Read and advise	Balances, forecast, fee x-ray, routes, documents, logging	Agent alone; no payment tool
T1 Auto in a mandate	Rent and insurance to verified payees; small purchases under a signed limit	A mandate you signed with your passkey
T2 Ask	Anything else: you approve the exact order	Your passkey over the order hash
T3 Never	No approval, a new payee inside 24 h, above a signed cap, a trigger approving anything	Refused by rules and re-checked by payments

Code paths and tests for every tier: docs/security/self-assessment.md §2

THE FAMOUS AGENT MONEY HACKS, RECREATED

1 / 16

paid with Kassa’s guards: 7 refused, 8 stopped at a passkey prompt

Freysa: “approveTransfer handles incoming money”

ElizaOS: a fake memory of the landlord’s new IBAN

Chevrolet “$1 Tahoe, legally binding”

16 / 16

paid by an agent with no checks, same attacker intent

Grok and Bankrbot: a Morse-coded order relayed by a bot

AIXBT: a compromised operator queue

“Move funds to a safe account” push-payment fraud

49 cases: 38 refused, 10 at a passkey prompt, 1 paid · a tap-to-confirm chatbot pays the attacker in 11 of 16 · docs/evidence/attacks.json · kassa-sand.vercel.app/showcase

SECURITY AND COMPLIANCE

Controls you can check, risks we name

In place

- Passkeys (WebAuthn) for every approval and loosening
- Hash-chained ledger with signed checkpoints
- Sanctions screening, transliteration included
- Redaction before any model; AI consent; data export and erase
- 13 invariants, each with a code path and a test
- Identity check above EUR 1,000, enforced in rules and again in payments
- China mapping: PIPL, CSL, DSL, MLPS 2.0, JR/T 0171 and 0197

Known risks, documented

- Sandbox rails only; production needs a licensed partner
- Keys behind a key provider with rotation, no hardware KMS yet
- Self-assessed only: no external pentest yet
- Some stores in memory (single process)
- Demo-only switches (time, 24 h waits) are logged and bannered

Self-assessment: docs/security/self-assessment.md · privacy and compliance: docs/security/

EXECUTION EVIDENCE

Every claim leaves a log you can open

48 / 49

attack cases stopped: 38 refused, 10 at a passkey prompt; 1 paid (A5, a QR swapped after the check)

57 + 12

ledger entries verified: the business story (2 signed checkpoints, anchored on Sepolia) and the student tuition run

5

simulated personas: average, careful, bad actor, China context, security review

Evidence	Where
Attacks vs two baselines	docs/evidence/attacks.json, tap-confirm-baseline.json, naive-baseline.json
Ledger verification	docs/evidence/ledger-verify.json, sim/tuition-e2e.json (bun run ledger:verify)
Ledger anchored on Sepolia	docs/evidence/anchors.json: 2 signed checkpoints, tx 0x83b2…ba13 and 0xd889…8b2d
Live planner, judge build	docs/evidence/live-agent.md: 7 live turns; 0 of 3 attacks paid a new account, even when the fooled user approves
Reader accuracy, live model	docs/evidence/invoice-eval.json: 21 of 30 invoices exact, each field 83–97%

The attack suite uses scripted models that obey the attacker (it tests the guards); the live-agent and invoice runs use the real models.

CHECK IT YOURSELF

Every scoring criterion has a place you can open

40%

Task completion

Judge build: a private, onboarded copy of Dana per sign-in, no passkey device needed. Ask the agent to pay tuition (approve with the test key), run today’s scheduled payments (rent is paid inside the signed mandate, no prompt), export a credit record.

30%

Security and compliance

docs/security/self-assessment.md: tiers T0 to T3, 13 invariants with code and tests, known risks. Evidence room: replay the 16 attacks, tamper with the ledger.

30%

Innovation and interaction

Signed mandates for an AI payer, statement-based onboarding, a verifiable credit record, the China QR handoff.

Judge build: kassa-judge.vercel.app · evidence room: kassa-sand.vercel.app/showcase · submission map: README and docs/submission

WHERE IT STANDS

Built, tested, ready to inspect

2,680
automated tests passing: API, app, mock bank world, shared types

3
apps: web, iOS and KassaLite, one passkey-gated server

Next
a licensed e-money partner, an external pentest, more banks and countries

The agent can prepare anything. Only your signature can move your money.

Live demo: kassa-sand.vercel.app · evidence room: kassa-sand.vercel.app/showcase · code and docs: github.com/himoji/kassa